

Rotación Segura de APPROVAL_TOKEN

¿Qué es el APPROVAL_TOKEN?

Es una clave secreta y única que protege operaciones destructivas (borrar clientes, resetear base, etc.). Cada entorno (dev, staging, prod) tiene su propio token.

Cómo rotar el token manualmente

1. Asegurate de tener:

- El token actual (lo vas a necesitar para autorizar la rotación)
- La variable `SLACK_WEBHOOK_URL` y/o `SECURITY_ALERT_EMAILS` cargadas en el `.env`

2. Para probar sin hacer cambios:

```
cd backend
npm run ops:token:rotate:dev -- --dry-run
```

3. Para rotar realmente:

```
npm run ops:token:rotate:dev -- --approve --token=TOKEN_ACTUAL
```

Esto:

- Crea backup del `.env.development`
- Genera un nuevo token
- Lo reemplaza en el `.env`
- Loggea el cambio en `/ops/logs/token_rotation.log`
- Envía alerta por Slack y/o Email
- Muestra el nuevo token en la terminal (copialo y guardalo bien)

4. Para staging:

```
npm run ops:token:rotate:staging -- --approve --token=TOKEN_ACTUAL
```

Historial de rotaciones

- El historial se guarda en:

```
backend/ops/logs/token_rotation.log
```

- Incluye: fecha, entorno, usuario que ejecutó, token enmascarado, y archivo modificado.

Rotar desde CI (GitHub Actions)

Si está configurado `workflow_dispatch`, podés rotar tokens desde la pestaña Actions en GitHub:

1. Entrá al repo
2. Pestaña **Actions** > **Rotate Approval Token**
3. Click en **Run workflow**
4. Seleccioná entorno (dev / staging)
5. Pegá el token actual
6. Confirmá

Auditoría y Seguridad

- Los tokens nunca se muestran completos en los logs ni en Slack/email.
- Solo se imprimen completos en la terminal local.
- Siempre se genera un backup automático antes de sobrescribir un `.env`

Recuperar token anterior (por si algo salió mal)

1. Buscá el backup creado:

```
backend/backups/.env.development.2025-10-14T13-30-00.bak
```

1. Restauralo:

```
cp backend/backups/.env.development.2025-10-14T13-30-00.bak
backend/.env.development
```

1. Reiniciá el backend:

```
npm run start:dev
```

Buenas prácticas

- Nunca compartas el APPROVAL_TOKEN por Slack o mail sin cifrar.
- No subas los `.env` a GitHub.
- Rotá el token al menos 1 vez al mes o al cambiar personal técnico.
- Configuraré notificaciones para que nunca pases una rotación sin alerta.

✉ Contacto seguridad: seguridad@trainfit.dev  Responsable de tokens: Flor Musitani